

Advanced Security and Privacy

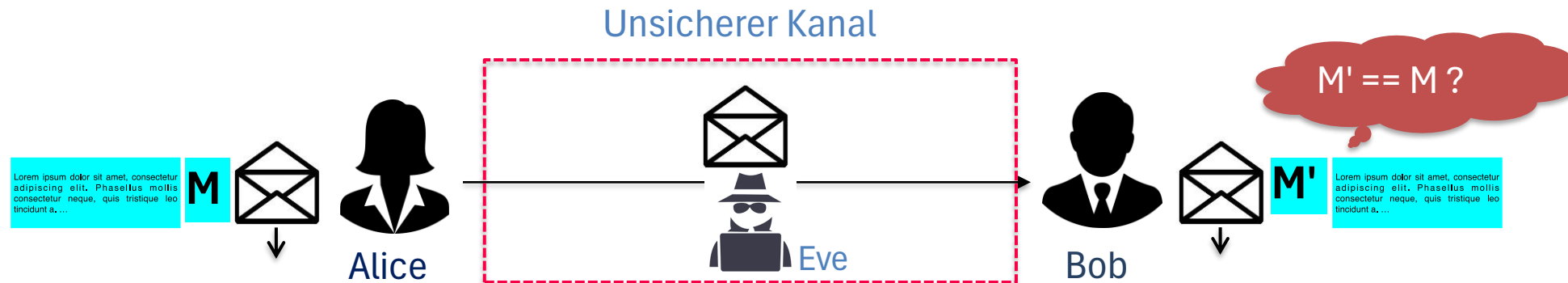
*Hash, MAC, HMAC, CMAC,
Digitale Signaturen*

Dr. Kevin Theuermann

*Wie schützt man die Integrität
(Unveränderbarkeit) von
Informationen?*

Integrität

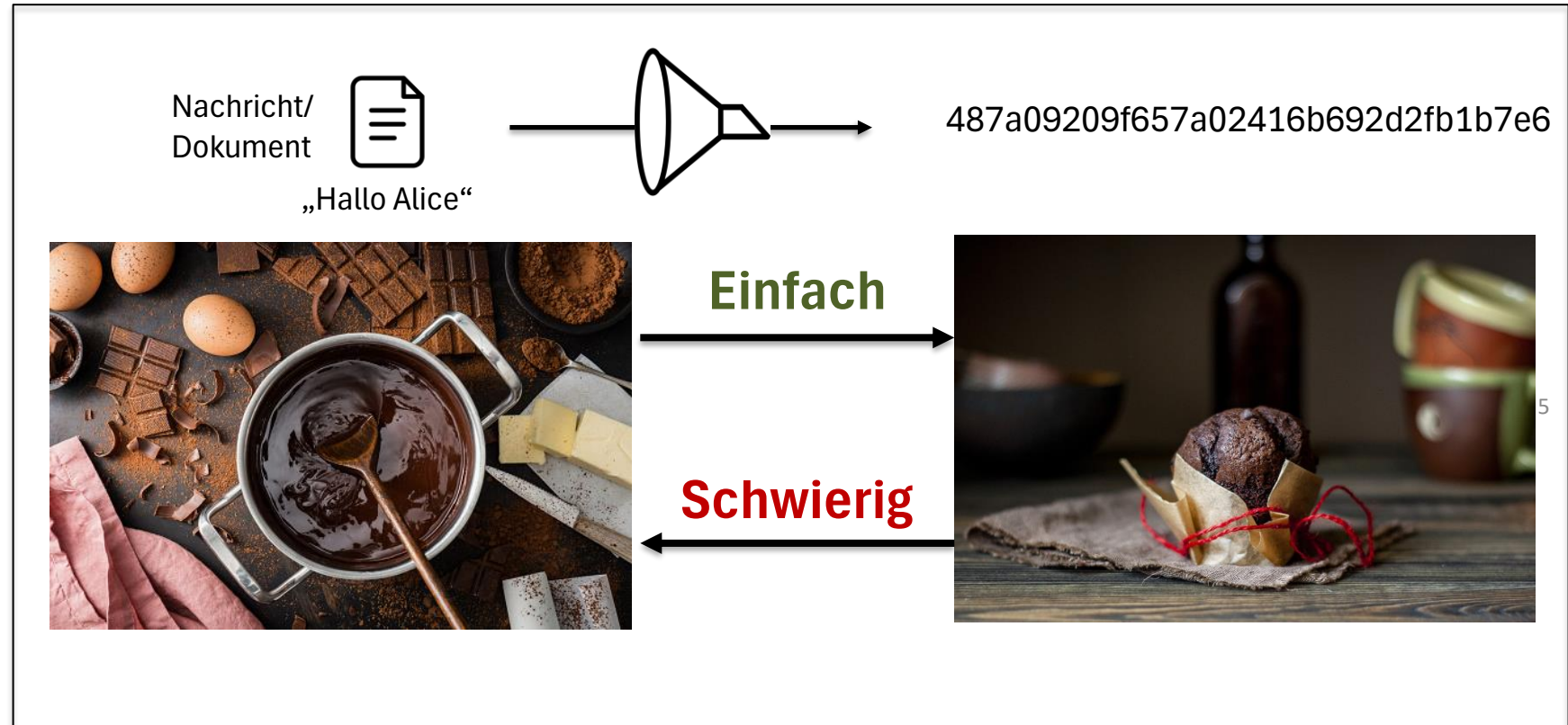
- Alice & Bob kommunizieren über unsicheren Kanal
 - Ziel: Nachricht soll **unverändert** beim Empfänger ankommen.
 - Lösung: Hash-Funktion, MACs oder digitale Signaturen



HASH-Funktion

Hash-Funktion

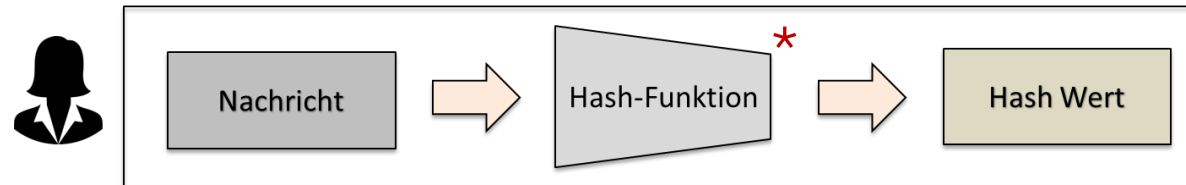
- Mathematische Einwegfunktion
- Nicht invertierbar
- Kollisionsfrei
- Viele Algorithmen:
 - MD2
 - SHA256
 - Uvm.



Wie nutzt man die Hash-Funktion zum Schutz der Integrität von Nachrichten?

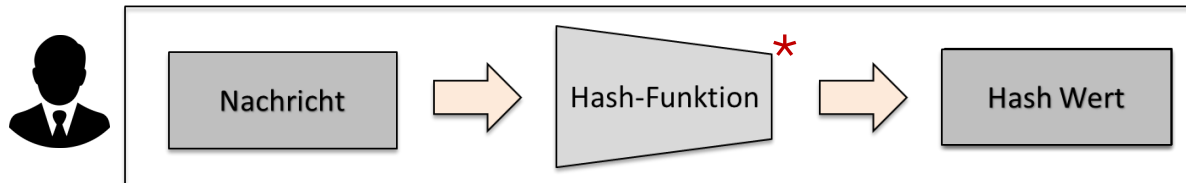
Hash-Funktion

1. Sender berechnet Hash-Wert der Nachricht



★ Gleicher Algorithmus

2. Sender übermittelt Nachricht und Hash-Wert an Empfänger
3. Empfänger berechnet Hash-Wert der empfangenen Nachricht



4. Empfänger vergleicht errechneten und empfangenen Hash-Wert

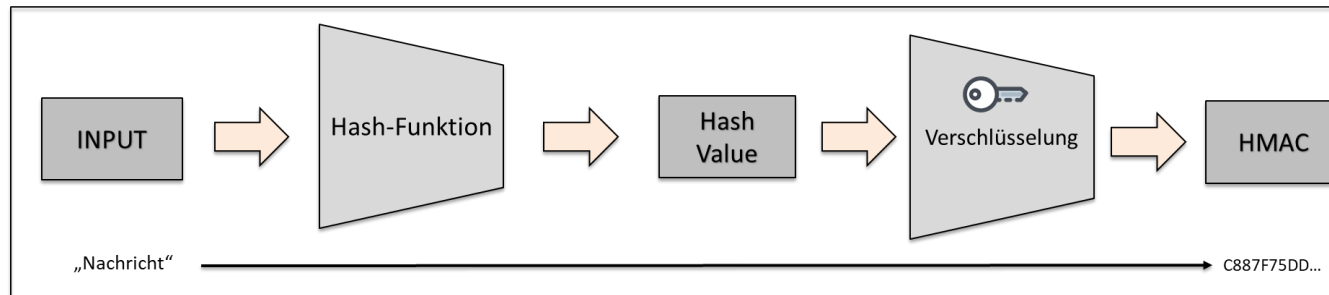


5. Bei Übereinstimmung: Nachricht unverändert

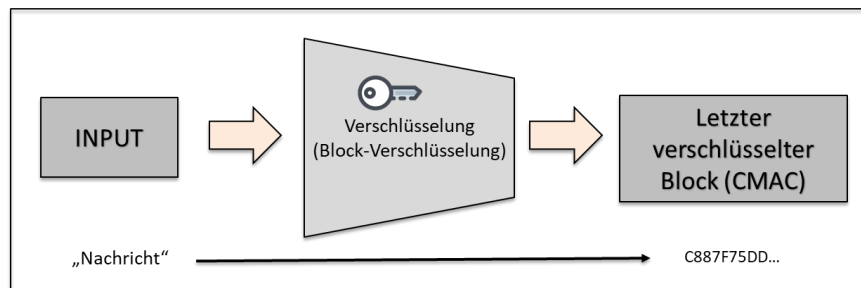
MAC, HMAC, CMAC

Message Authentication Codes

- MAC bezeichnet eine Obergruppe verschiedener Funktionen:
- HMAC: Berechnung mit Hash + geheimer symmetrischer Schlüssel (z.B. AES)



- CMAC: Letzter verschlüsselter Block der Nachricht bei Blockverschlüsselung

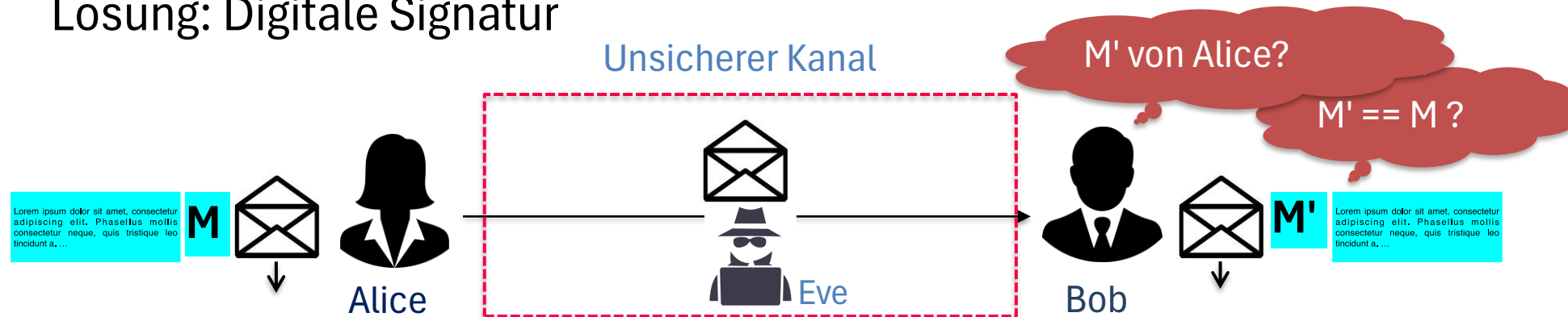


Integrität kann nur durch einen bestimmten Empfänger (der im Besitz des symmetrischen Schlüssels ist) geprüft werden

Digitale Signaturen

Integrität + Authentizität

- Alice & Bob kommunizieren über unsicheren Kanal
 - Der Empfänger soll eine unveränderte Nachricht erhalten und wissen, wer ihr Absender bzw. der Ersteller der übermittelten Nachricht war.
 - Lösung: Digitale Signatur

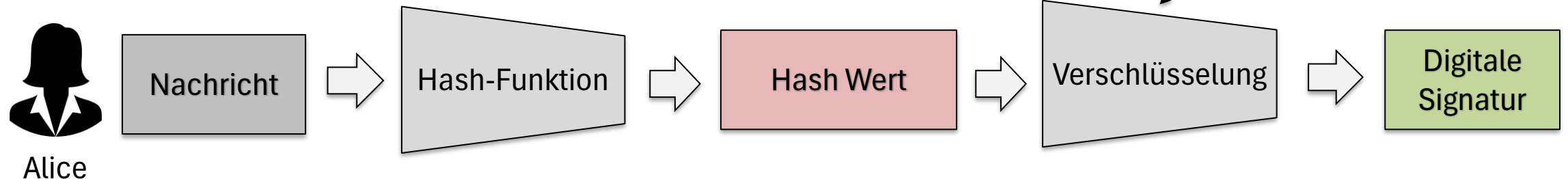


Digitale Signaturen | Signaturerstellung

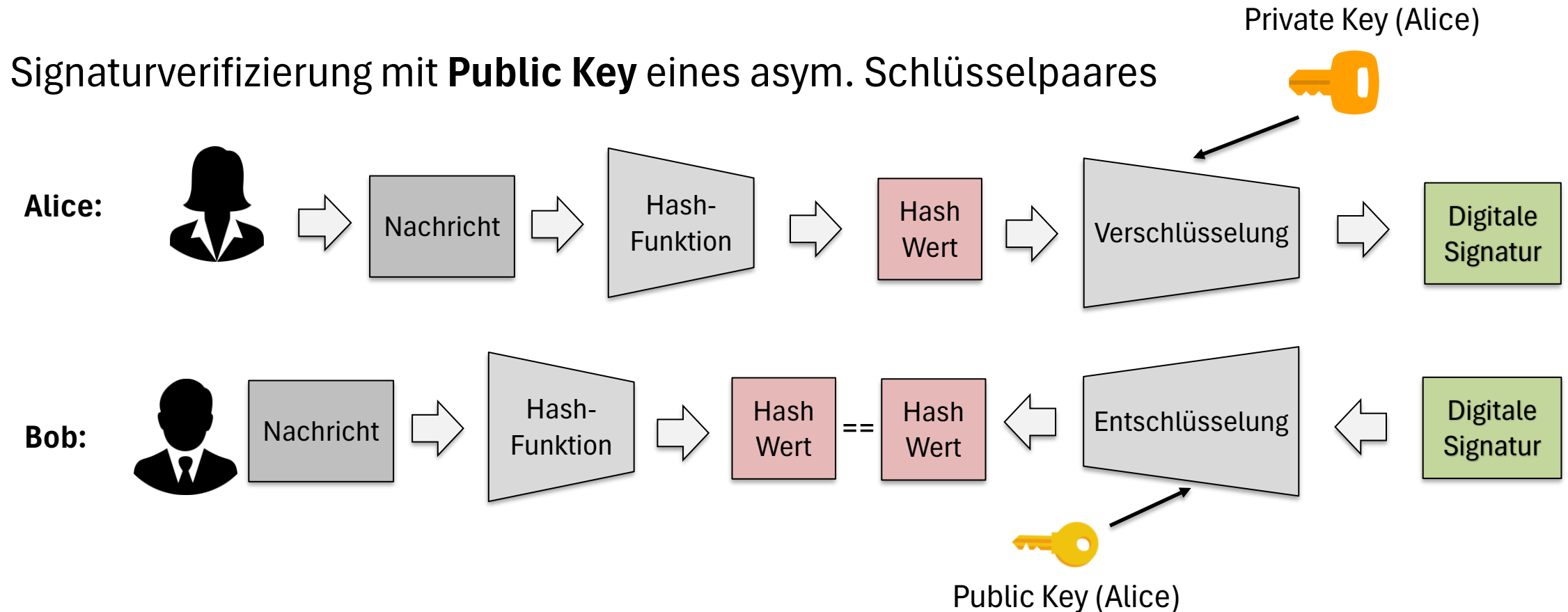
Signaturerstellung mit **Private Key** eines asym. Schlüsselpaares

Signaturerstellung

1. Erstellen der Nachricht/des Dokuments
2. Berechnung des Hash-Wertes
3. Verschlüsseln des Hash-Wertes mit dem Private Key
4. Übermitteln der Nachricht, digitalen Signatur und Public Key



Digitale Signaturen | Signaturverifizierung



Angriffsmodel

Angriffe	Beschreibung
Nachricht lesen	Angreifer kann die Daten lesen.
Indirektes Ableiten von Informationen	Angreifer kann die Daten lesen.
Kommunikation aufzeichnen und mit (gestohlenen) Schlüssel entschlüsseln	Kommunikation kann aufgezeichnet und mit einem gestohlenen Schlüssel entschlüsselt werden.
Replay-Angriff	Weiterhin möglich
Verändern der unverschlüsselten Nachricht	Wird durch einen Hash-Wert, einen MAC oder eine digitale Signatur geschützt
Verändern der verschlüsselten Nachricht	Wird durch einen Hash-Wert, einen MAC oder eine digitale Signatur geschützt
Impersonisieren	Verwendeter Schlüssel muss eindeutig an eine Identität gebunden sein.
Nachricht unterdrücken	Möglich



Angriff ist unter den
genannten Annahmen
nicht möglich

Auswirkung des Angriffs
hängt vom Szenario ab

Angriff ist erfolgreich



Wie kann man einen Schlüssel (Public/Private Key) an eine Person binden?

Identitätsbindung der Schlüssel

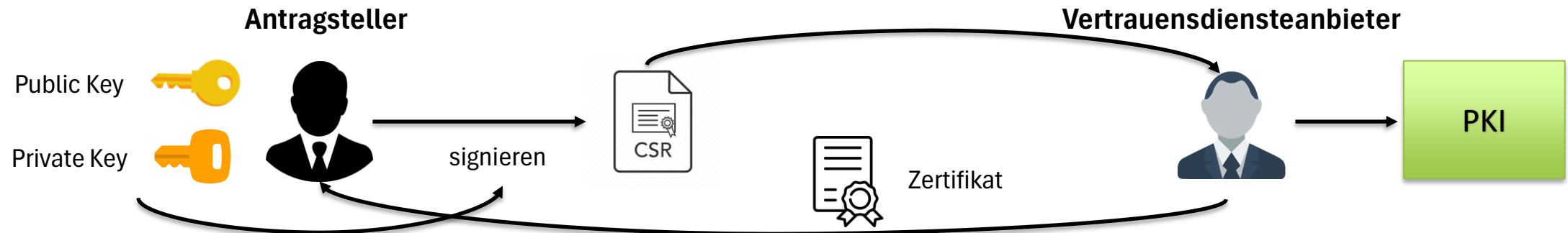
Digitale Signaturen:

- Verwendung von öffentlichen **digitalen Zertifikaten (optional)**:
 - Public Key ist exakt einer Person zugeteilt (Unterzeichner)
 - Zertifikat beinhaltet Public Key und Daten des Schlüsselbesitzers
 - Verteilung des Zertifikats durch Akteure, die Public-Key-Infrastruktur verwenden
 - Ausstellung eines Zertifikats erfordert Authentifizierung des Schlüsselbesitzers

X.509 Zertifikat von X	
Public Key von X	
Seriennummer des Zertifikates	
Gültigkeitszeitraum	
Eindeutiger Name von X	
Eindeutiger Name der Zertifizierungsstelle	
Digitale Unterschrift der Zertifizierungsstelle	

Public Key Registrierung | Zertifikatsanforderung

1. Certificate Signing Request (CSR) = Zertifikatsignierungsanforderung
2. Antragsteller erzeugt ein Schlüsselpaar und einen CSR und signiert ihn mit dem Private Key
3. Antragsteller sendet CSR inkl. Public Key an vertrauenswürdige (z.B. staatlich akkreditierte) Stelle
4. Vertrauensdiensteanbieter validiert CSR, erstellt ein Zertifikat und sendet es zurück an den Antragsteller



Public Key Infrastruktur (PKI)

Bestandteile:

1. Digitale Zertifikate
2. Zertifizierungsstelle (CA)
3. Registrierungsstelle (RA)
4. Zertifikatssperrliste
5. Verzeichnisdienst
6. Validierungsdienst

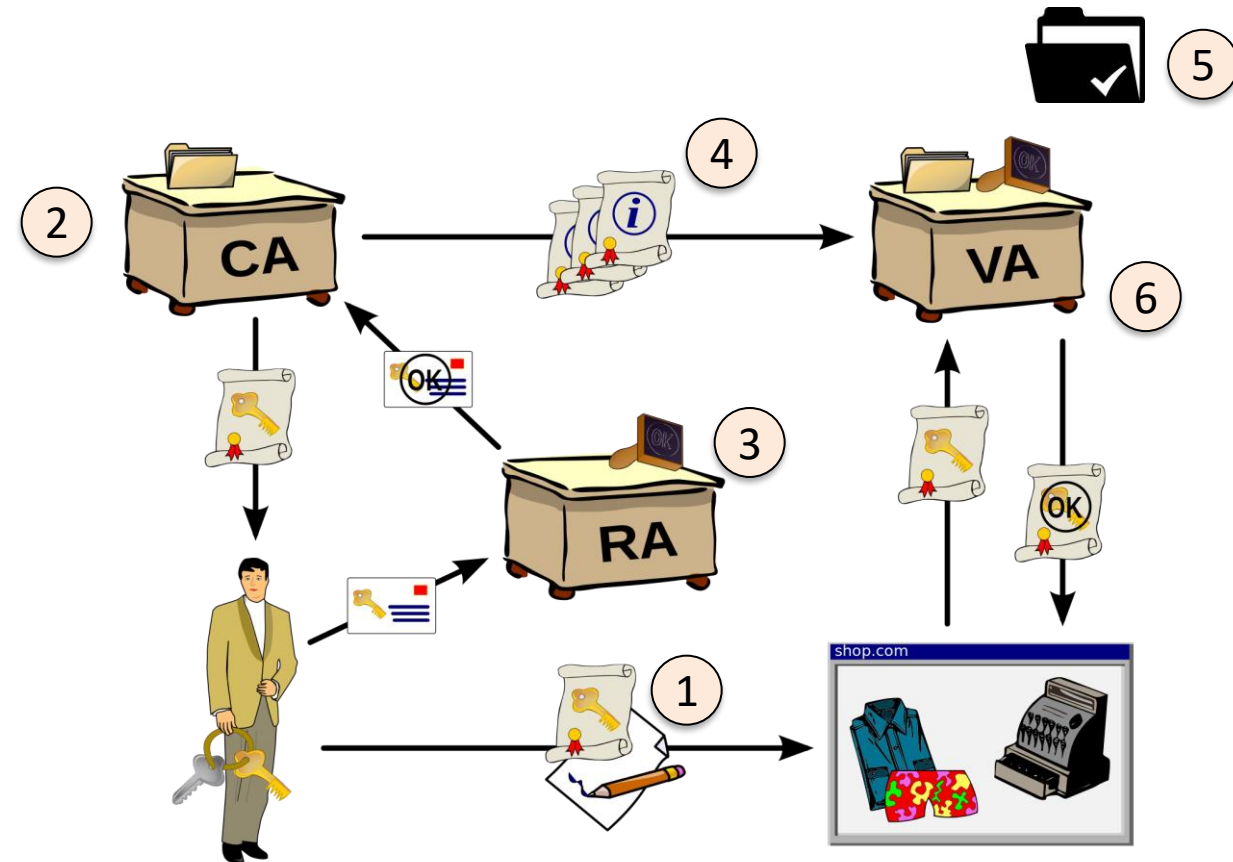
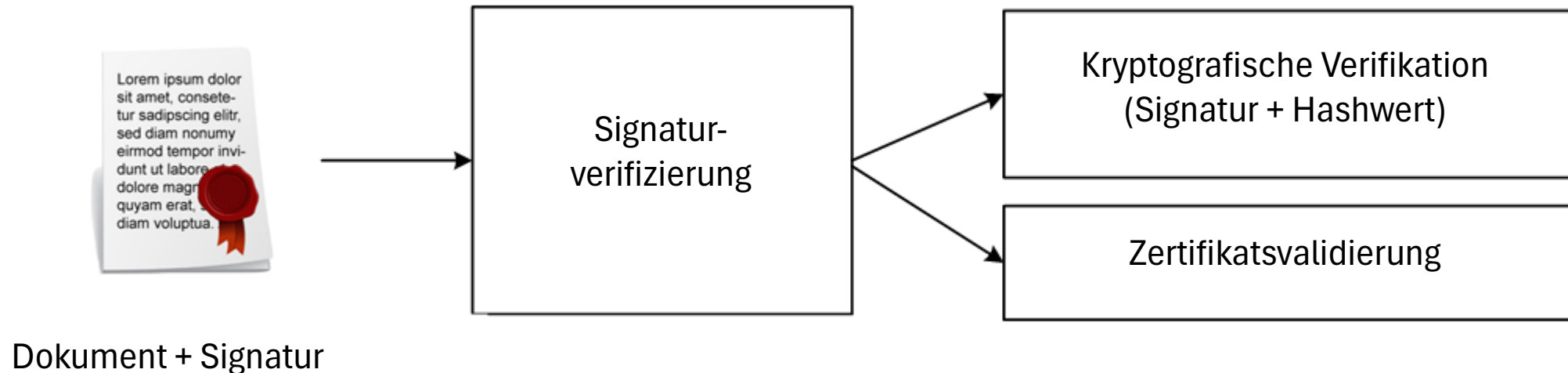


Foto: <https://upload.wikimedia.org/>

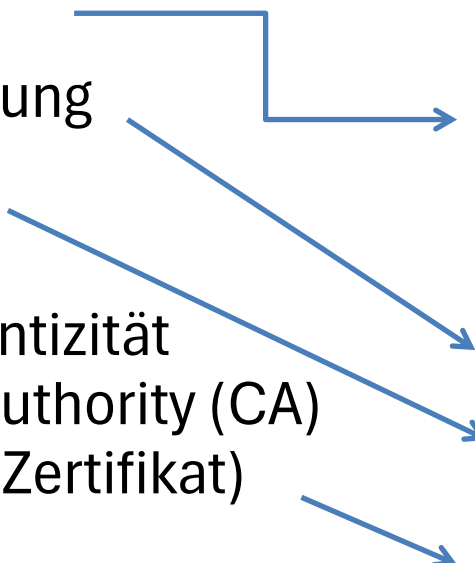
Signaturverifizierung



Bei der Signaturverifizierung muss neben der kryptografischen Verifikation auch eine Validierung des Zertifikats vorgenommen werden!

Signatur Verifikation | Verifikation des Zertifikats

X.509 Zertifikat

- Gültigkeitsperiode
 - Schlüsselerwendung
 - Überprüfung der Revozierung
 - Qualität der Authentizität (via Certification Authority (CA) oder qualifiziertes Zertifikat)
- 

X.509 Zertifikat

<i>Seriennummer:</i>	0F69BA
<i>Aussteller:</i>	CN=a-sign-Premium-Sig-02 [...]
<i>Gültig ab:</i>	13.August 2013 17:43:22
<i>Gültig bis:</i>	13.August 2018 15:43:22
<i>Antragsteller:</i>	CN=Klaus Stranacher
<i>Öffentlicher Schlüssel:</i>	04EF2835ABFE81F...
<i>Schlüsselerwendung:</i>	Digitale Signatur
<i>Widerrufsinfo.:</i>	OCSP/CRL URL
<i>Qual. Zertifikat:</i>	Ja
<i>Sichere Sig.erst.einh.:</i>	Ja
<i>Etc.</i>	

Signatur Verifikation | Verifikation des Zertifikats

X.509 Zertifikat

ID bzw. Personenbindung = ""

<i>Seriennummer:</i>	0F69BA
<i>Aussteller:</i>	CN=a-sign-Premium-Sig-02 [...]
<i>Gültig ab:</i>	13.August 2013 17:43:22
<i>Gültig bis:</i>	13.August 2018 15:43:22
<i>Antragsteller:</i>	CN=Klaus Stranacher
<i>Öffentlicher Schlüssel:</i>	04EF2835ABFE81F...
<i>Schlüsselverwendung:</i>	Digitale Signatur
<i>Widerrufsinfo.:</i>	OCSP/CRL URL
<i>Qual. Zertifikat:</i>	Ja
<i>Sichere Sig.erst.einh.:</i>	Ja
<i>Etc.</i>	

*Eindeutiger Identifier
der Person notwendig!*

Welche Angriffe können mit digitalen Signaturen und Zertifikaten verhindert werden?

Angriffsmodel

Angriffe	Beschreibung
Nachricht lesen	Angreifer kann die Daten lesen.
Indirektes Ableiten von Informationen	Angreifer kann die Daten lesen.
Kommunikation aufzeichnen und mit (gestohlenem) Schlüssel entschlüsseln	Angreifer kann die Daten lesen.
Replay-Angriff	Digitale Signaturen sind deterministisch. D.h. ich kann mit demselben Input + Schlüssel immer den gleiche Signatur berechnen.
Verändern der unverschlüsselten Nachricht	Ein Angreifer kann unverschlüsselte Nachrichten nicht unbemerkt verändern.
Verändern der verschlüsselten Nachricht	Ein Angreifer kann unverschlüsselte Nachrichten nicht unbemerkt verändern.
Impersonisieren	Die Identität ist durch ein digitales Zertifikat bestätigt.
Nachricht unterdrücken	Möglich



Angriff ist unter den
genannten Annahmen
nicht möglich

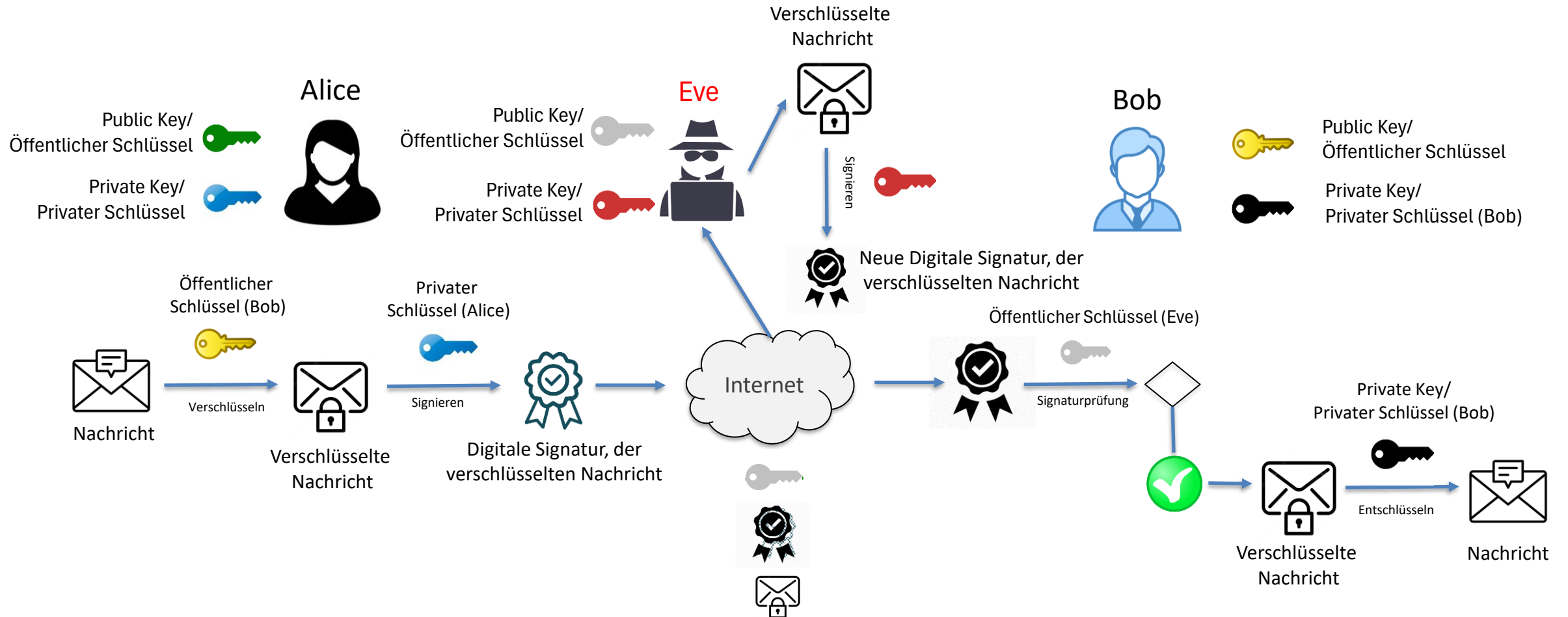
Auswirkung des Angriffs
hängt vom Szenario ab

Angriff ist erfolgreich

Wird die **verschlüsselte** oder **unverschlüsselte** Nachricht signiert?

- Überlegen Sie eventuelle Sicherheitsprobleme beim Signieren von Nachrichten.
- Wird zuerst verschlüsselt und dann signiert, oder umgekehrt?
- Zeit: 10min mit anschließender Diskussion

Erst verschlüsseln, dann signieren



Erst verschlüsseln, dann signieren

- Ein Angreifer kann die verschlüsselte Nachricht und die Signatur abfangen
- Ein Angreifer kann eine neue digitale Signatur mit seinem privaten Schlüssel erzeugen und diese mit der verschlüsselten Nachricht an den Empfänger senden
- Der Empfänger glaubt nach einer erfolgreichen Signaturverifizierung, dass die Nachricht vom Angreifer erstellt wurde
- **Daher:** Zuerst signieren und dann verschlüsseln (!)

Angriffsmodell

Angriffe	Beschreibung
Nachricht lesen	Nicht möglich, da die Daten verschlüsselt sind.
Indirektes Ableiten von Informationen	Metadaten evtl. durch Verschlüsselungsmodus und –algorithmus ableitbar.
Kommunikation aufzeichnen und mit (gestohlenem) Schlüssel entschlüsseln	Möglich.
Replay-Angriff	Signaturen/MAC sind deterministisch. D.h. ich kann mit demselben Input und Schlüssel immer den gleichen MAC bzw. die gleiche Signatur berechnen.
Verändern der unverschlüsselten Nachricht	Nicht möglich durch den Einsatz von digitalen Signaturen/MACs (Integritätsschutz).
Verändern der verschlüsselten Nachricht	Nicht möglich durch den Einsatz von digitalen Signaturen/MACs (Integritätsschutz).
Impersonalisieren	Nicht möglich, wenn der verwendete Signaturschlüssel an die Identität des Besitzers gebunden ist (z.B. durch ein digitales Zertifikat).
Nachricht unterdrücken	Möglich



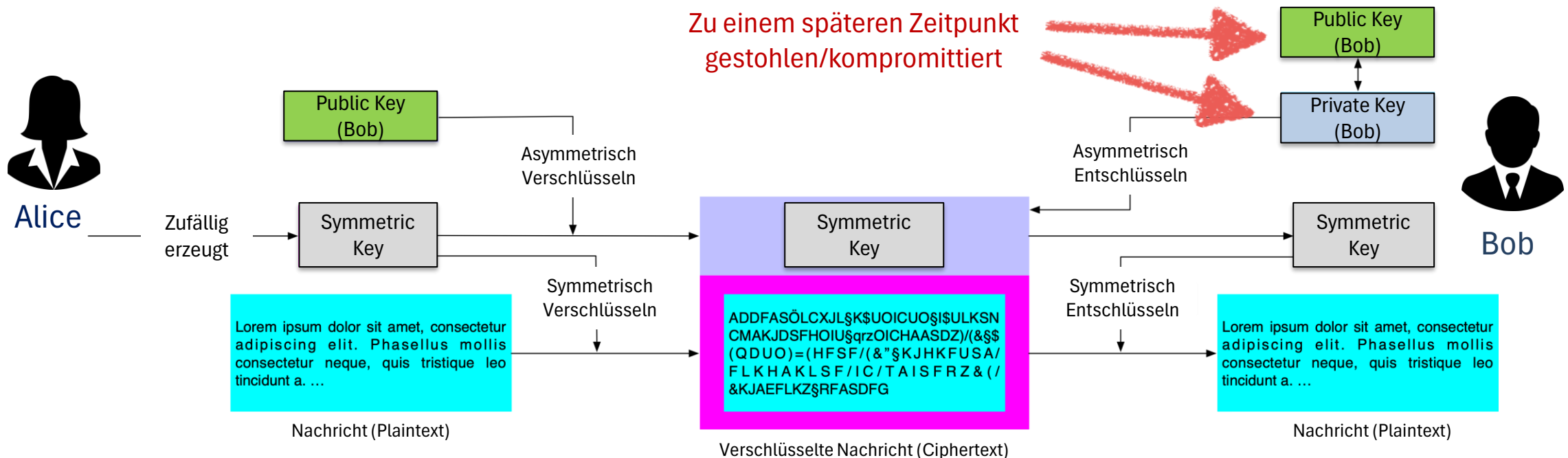
Angriff ist unter den
genannten Annahmen
nicht möglich

Auswirkung des Angriffs
hängt vom Szenario ab

Angriff ist erfolgreich

Hybride Verschlüsselung | Offene Probleme

- Eine dritte Partei (Eve) kann alle verschlüsselten Nachrichten speichern
- Diebstahl von symmetrischen Schlüssel ermöglicht Entschlüsselung aller Nachrichten

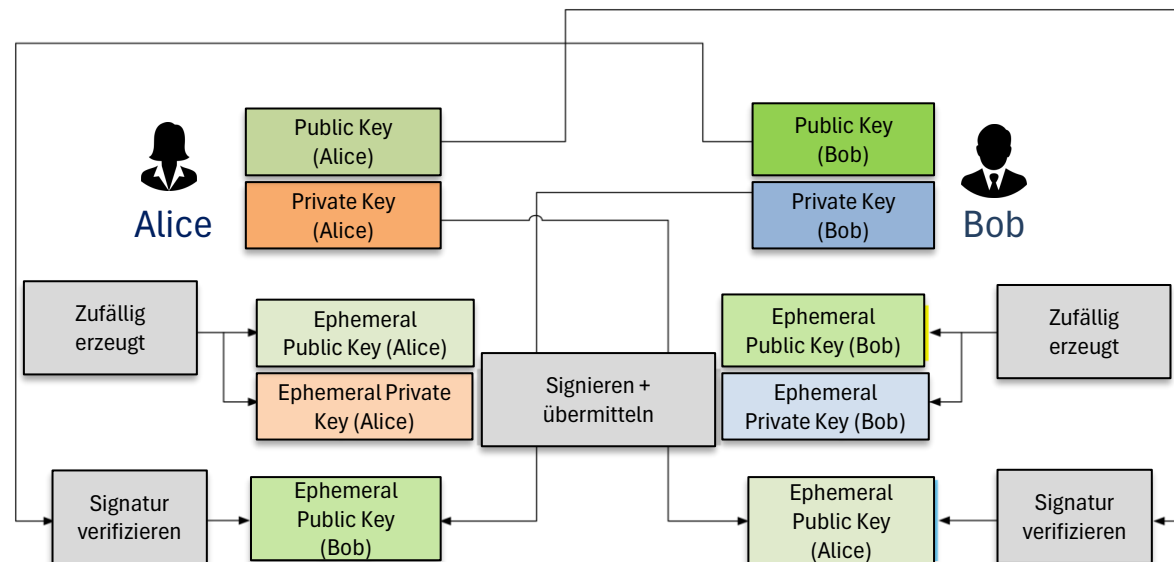


Perfect Forward Secrecy

Dr. Kevin Theuermann

Perfect Forward Secrecy

- Sender: Alice, Empfänger: Bob
- Beide verfügen über asymmetrisches Schlüsselpaar (Statische Schlüssel), Algorithmen: ECC oder RSA
- Vor der Kommunikation:
 - (Ephemeral) ECC-Schlüsselpaare werden erzeugt *RSA-Algorithmus zu langsam für die Erzeugung von Ephemeral Keys*
 - Ephemeral Public Keys werden ausgetauscht und mit statischem privatem Schlüssel signiert (sichert Vertrauen)
 - **Symmetrischer Schlüssel** wird mit Ephemeral Public Keys über das Diffie-Hellman-Merkle Protokoll berechnet
 - (Ephemeral) ECC-Schlüsselpaare und der symmetrische Schlüssel werden nach der Kommunikation gelöscht



Angriffsmodell

Angriffe	Beschreibung	
Nachricht lesen	Nicht möglich, da die Daten verschlüsselt sind.	✓
Indirektes Ableiten von Informationen	Metadaten evtl. durch Verschlüsselungsmodus und –algorithmus ableitbar.	✓
Kommunikation aufzeichnen und mit (gestohlenen) Schlüssel entschlüsseln	Wird durch Perfect Forward Secrecy verhindert.	
Replay-Angriff	Möglich. Ein Man-in-the-Middle kann den verschlüsselten Text abfangen und erneut versenden.	
Verändern der unverschlüsselten Nachricht	Nicht möglich durch den Einsatz von digitalen Signaturen/MACs (Integritätsschutz).	✓
Verändern der verschlüsselten Nachricht	Nicht möglich durch den Einsatz von digitalen Signaturen/MACs (Integritätsschutz).	✓
Impersonisieren	Nicht möglich, wenn der verwendete Signaturschlüssel an die Identität des Besitzers gebunden ist (z.B. durch ein digitales Zertifikat).	✓
Nachricht unterdrücken	Möglich	

Angriff ist unter den
genannten Annahmen
nicht möglich

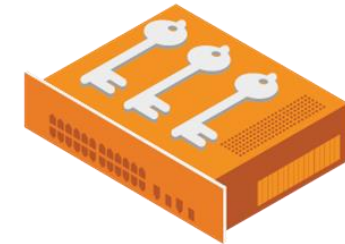
Auswirkung des Angriffs
hängt vom Szenario ab

Angriff ist erfolgreich

Perfect Forward Secrecy | Offene Probleme

Sichere Speicherungen/Erzeugung von Schlüsselmaterial:

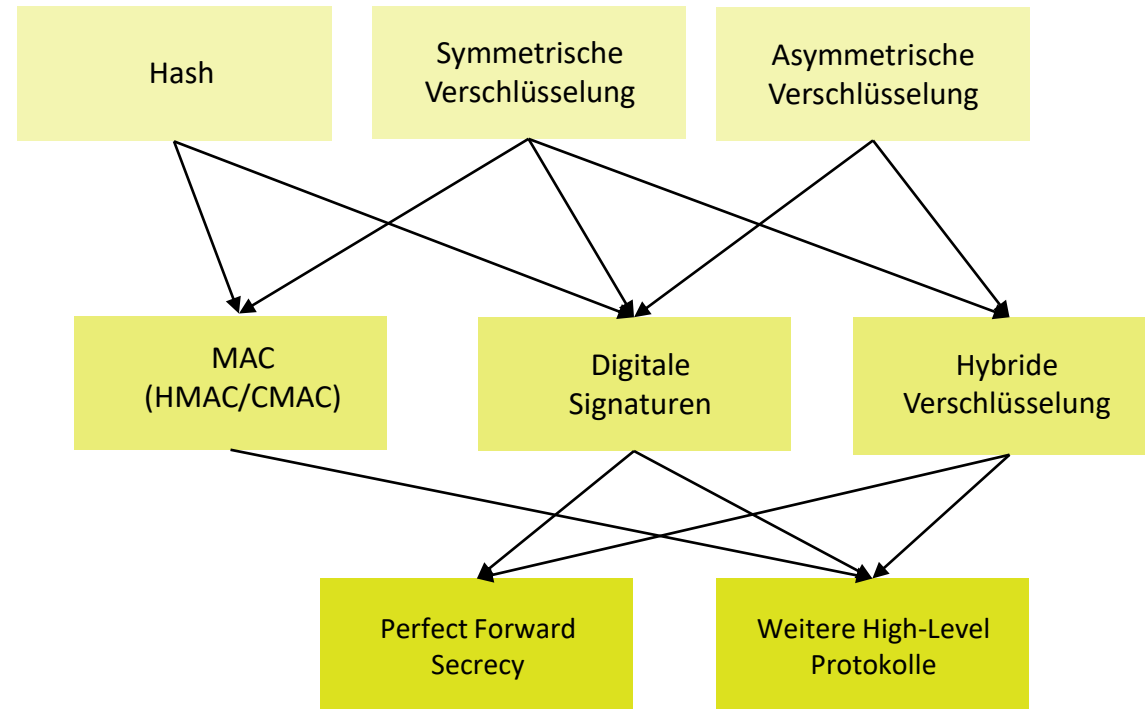
- **Risiko:** Unsichere Software Keystores
- Sichere Schlüsselerstellung erfordert spezielle Hardware
 - Secure Elements (Android)/Secure Enclave (iOS) für mobile Geräte
 - Key Attestation auf Smartphones
 - Hardware Security Modules (HSM)
- Beeinflusst die Qualität einer Authentifizierung: Level of Assurance (LoA)



eIDAS regulation: Level of Assurance

Big Picture

Basis-Schutzmethoden- Security Controls



Angriff	Security Control	Hash	MAC (HMAC/CMAC)	Symmetrische Verschlüsselung	Asymmetrische Verschlüsselung	Digitale Signaturen	Hybride Verschlüsselung	Perfect Forward Secrecy
Nachricht lesen		✗	✗	✓	✓	✗	✓	✓
Indirektes Ableiten von Informationen		✗	✗	✓	✓	✗	✓	✓
Kommunikation aufzeichnen und mit (gestohlenem) Schlüssel entschlüsseln		✗	✗	✗	✗	✗	✗	✓
Nachricht einfügen		✓	✓	✓	✗	✓	✗	✓
Replay-Angriff		✗	✗	✗	✗	✗	✗	✗
Verändern der unverschlüsselten Nachricht		✓	✓	✓	✓	✓	✓	✓
Verändern der verschlüsselten Nachricht		✗	✗	✗	✗	✓	✗	✓
Impersonisieren		✗	✓	✓	✓	✓	✗	✓
Nachricht unterdrücken		✗	✗	✗	✗	✗	✗	✗
Angriff ist unter den genannten Annahmen nicht möglich		Auswirkung des Angriffs hängt vom Szenario ab			Angriff ist erfolgreich			

→ Wird auf Protokollebene verhindert (z.B. Timestamps)

→ Maßnahmen wie Blackhole Routing gegen DDoS-Angriffe